# Trousse d’évaluation CyberRiskGuardian

## Énoncés de travaux, grilles d’évaluation et autovérifications — Ensemble pédagogique 2.1.2

Marc-André Léger, Ph. D.

novembre 2026

## Table des matières

1 Comment utiliser cette trousse ..... 2

2 L’échelle de 0 à 10 ..... 2

2.1 Comment la note est calculée ..... 3

3 Six vérifications appliquées à chaque travail ..... 4

4 A1 — Évaluation des risques de cybersécurité (en équipe) ..... 4

4.1 Énoncé ..... 4

4.2 Livrables ..... 5

4.3 Grille d’évaluation ..... 5

4.4 Autovérification avant la remise ..... 7

4.5 Conseils ..... 7

5 A2 — Politique de sécurité de l’information : gestion des identités et des accès (en équipe) ..... 7

5.1 Énoncé ..... 8

5.2 Grille d’évaluation ..... 8

5.3 Autovérification ..... 9

6 A3 — Plan d’audit de cybersécurité fondé sur les risques (individuel) ..... 9

6.1 Énoncé ..... 10

6.2 Grille d’évaluation ..... 10

6.3 Autovérification ..... 11

7 Formats plus courts ..... 11

7.1 Portfolio de laboratoires (individuel, réussite/échec ou 10 %) ..... 11

7.2 Essai individuel sur un scénario de risque (individuel, 2 ou 3 pages) ..... 11

7.3 Défi d’analyse rapide en classe (en équipe, 75 minutes) ..... 12

7.4 Dissertation d’examen (individuelle, en personne, sans IA) ..... 12

8 Formulaire d’évaluation par les pairs pour les travaux d’équipe ..... 12

9 Déclaration d’utilisation de l’IA générative ..... 12

# 1 Comment utiliser cette trousse

Cette trousse fournit aux enseignants des énoncés de travaux et des grilles d’évaluation prêts à adapter pour les cours qui utilisent CyberRiskGuardian, et présente aux étudiants les critères selon lesquels leurs travaux seront évalués. Elle s’appuie sur la conception de l’évaluation d’un cours de premier cycle en cybersécurité, généralisée afin que tout établissement puisse l’utiliser.

**Pour les enseignants.** Remplacez les éléments entre crochets — [semaine de remise], [pondération], [nombre de pages maximal], [plateforme de remise], [permis / non permis] — par les vôtres. Conservez les critères et les descripteurs : ce sont eux qui assurent la cohérence de la correction entre les groupes-cours et les auxiliaires d’enseignement. Votre plan de cours et vos consignes de travaux demeurent la source qui fait autorité ; dites-le aux étudiants.

**Pour les étudiants.** Lisez la grille d’évaluation avant de commencer, et non après. Chaque critère vous indique ce que démontre un travail solide. Utilisez la liste d’autovérification avant de remettre votre travail.

La trousse contient :

1. L’échelle de notation de 0 à 10 et la façon dont la note d’un travail est calculée.
2. Six vérifications appliquées à chaque travail.
3. Trois travaux principaux : **A1** évaluation des risques (en équipe), **A2** politique de sécurité (en équipe), **A3** plan d’audit fondé sur les risques (individuel).
4. Quatre formats plus courts : portfolio de laboratoires, essai individuel sur un scénario de risque, défi d’analyse rapide en classe, dissertation d’examen.
5. Un formulaire d’évaluation par les pairs pour le travail d’équipe et la déclaration d’utilisation de l’IA générative.

Les corrigés des laboratoires, une banque de questions de quiz notées, des exemples d’étalonnage des grilles d’évaluation et une banque de commentaires de rétroaction se trouvent dans l’Édition Éducateur.

# 2 L’échelle de 0 à 10

Chaque critère de chaque travail est noté de 0 à 10. Un **10** représente une atteinte exceptionnelle de tous les critères ; un **6** représente une atteinte satisfaisante des exigences essentielles.

| Note | Niveau | Description |
|---|---|---|
| 10 | Exceptionnel | Satisfait pleinement ou dépasse toutes les exigences, avec une compréhension exceptionnelle, une analyse rigoureuse, de l’exactitude, de l’originalité et une présentation remarquable |
| 9 | Excellent | Toutes les exigences, à un niveau très élevé ; seulement des lacunes négligeables |

| Note | Niveau | Description |
|---|---|---|
| 8 | Très bien | Presque toutes les exigences, une compréhension solide et une analyse efficace ; quelques faiblesses mineures |
| 7 | Bien | La plupart des exigences, une bonne compréhension et une exécution généralement solide ; certaines faiblesses ou une profondeur limitée |
| 6 | Satisfaisant | Les exigences essentielles, une compréhension adéquate ; des faiblesses, omissions ou une analyse limitée notables |
| 5 | Passable | Satisfait partiellement les exigences ; omissions, inexactitudes ou faiblesses importantes |
| 4 | Sous les attentes | Seulement un nombre limité d'exigences ; compréhension insuffisante ou erreurs substantielles |
| 3 | Faible | Ne satisfait pas la plupart des exigences ; incompréhensions conceptuelles majeures |
| 2 | Très faible | Ne traite qu'une petite partie ; lacunes graves |
| 1 | Effort minimal | Contenu pertinent négligeable |
| 0 | Aucun travail évaluable | Aucune remise, ou rien de pertinent à évaluer |

## 2.1 Comment la note est calculée

1. Chaque travail comporte de six à huit critères, chacun pondéré.
2. La note du travail est la moyenne pondérée des notes des critères, sur 10.
3. Certaines exigences **plafonnent** un critère : si un élément requis est absent ou si un chiffre est inventé, la note de ce critère est limitée, quelle que soit la qualité du reste.
4. La note × 10 donne un pourcentage. Toute pénalité de retard prévue par le cours est ensuite appliquée à la note obtenue.
5. Pour chaque critère noté sous 10, l'étudiant reçoit les principales lacunes et ce qui lui permettrait d'obtenir une note plus élevée.

**Exemple résolu (A1, six critères) :**

| Critère | Pondération | Note | Pondération × note |
|---|---|---|---|
| Scénario de risque S1 — pertinence et originalité | 20 % | 8 | 1,6 |
| Tableaux d'analyse des risques — exhaustivité et précision | 20 % | 7 | 1,4 |
| Mesures d'atténuation — pertinence | 20 % | 6 | 1,2 |
| Mémorandum — clarté et argumentation | 20 % | 8 | 1,6 |
| Présentation et qualité rédactionnelle | 10 % | 9 | 0,9 |
| Synthèse et conclusions stratégiques | 10 % | 7 | 0,7 |
| **Note du travail** | | | **7,4 / 10 = 74 %** |

**Principes de correction :** cohérence (les mêmes descripteurs pour tous), évaluation fondée sur les preuves (les notes reflètent ce que le travail démontre, et non l'effort), proportionnalité (des problèmes mineurs de présentation ne l'emportent pas sur une réalisation substantielle, à moins que la présentation ne soit elle-même le critère) et rétroaction pour chaque critère noté sous 10.

# 3 Six vérifications appliquées à chaque travail

| # | Vérification | Ce que cela signifie |
|---|---|---|
| 1 | Exhaustivité | Chaque livrable et chaque section requis sont présents, dans les limites de pages |
| 2 | Fidélité au cas et aux preuves | Les faits proviennent du cas et de sources crédibles citées ; chaque affirmation est qualifiée de fait, d'inférence, d'estimation, d'hypothèse ou de recommandation ; aucun fait du cas n'est inventé |
| 3 | Utilisation correcte des modèles et des cadres | CyberRiskGuardian, CVSS, NIST CSF 2.0, ISO/IEC 27001 et 27002:2022, COBIT 2019 et les normes d'audit sont appliqués au cas, et non seulement nommés |
| 4 | Exactitude numérique et technique | Les chiffres se situent dans des plages valides, peuvent être recalculés et concordent dans tous les fichiers ; les calculs sont présentés |
| 5 | Recommandations applicables | Précises, priorisées, chiffrées, avec les compromis, les responsables, le risque résiduel et les hypothèses |
| 6 | Professionnalisme | Page titre avec chaque auteur et son matricule, citations cohérentes (APA 7 ou IEEE), langage de niveau direction, déclaration explicite d'utilisation de l'IA générative |

**Vérifiez chaque identifiant.** La numérotation des cadres change d'une version à l'autre : NIST CSF 1.1 et 2.0 utilisent des codes de sous-catégories différents ; ISO/IEC 27001:2013 et 2022 numérotent leurs contrôles différemment. Un code qui n'existe pas, ou qui est utilisé à mauvais escient, nuit à l'exactitude du critère où il apparaît. Les outils d'IA générative inventent fréquemment de tels codes.

**Problèmes de qualité fréquents.** Répéter les faits du cas sans les analyser · présenter un chiffre, un vecteur CVSS ou une correspondance de contrôles générés par l'IA comme vérifiés · choisir d'abord une solution et inventer des risques pour la justifier · nommer un cadre sans le relier aux preuves · copier des gabarits ou des exemples résolus sans les adapter · « déversement de contrôles » (de nombreux contrôles sans préciser quel risque chacun traite, ce qu'il apporte et ce qu'il coûte) · des chiffres qui diffèrent d'un fichier à l'autre · traiter le score CVSS comme s'il était le risque · des recommandations sans coût, compromis, responsable ni séquence.

# 4 A1 — Évaluation des risques de cybersécurité (en équipe)

**Équipe de 3 ou 4 · Remise [semaine] · [Pondération, p. ex. 20 %] de la note du cours**

## 4.1 Énoncé

Votre équipe agit à titre de consultants en cybersécurité auprès de l'organisation décrite dans l'étude de cas qui vous a été attribuée. Réalisez une évaluation des risques de cybersécurité fondée sur des scénarios de risque avec CyberRiskGuardian et recommandez à la direction un portefeuille priorisé de traitements des risques.

1. **Créez un scénario de risque original (S1)** à l'aide du modèle de scénario du cours. Il doit se distinguer de chaque scénario fourni dans votre cas et dans les guides du cours.
2. **Analysez dix scénarios de risque** — S1 et neuf autres fournis par votre cas ou choisis par votre équipe dans sa bibliothèque de scénarios (S2 à S10) — avec les six paramètres CRG et un score CVSS v4.0 pour chacun (la v3.1 est acceptée si elle est utilisée de façon cohérente ; conservez le vecteur).
3. **Établissez l'appétence pour le risque de l'organisation**, en utilisant la tolérance au risque indiquée dans le cas ou une solution de rechange justifiée.
4. **Choisissez des mesures de traitement** pour ramener le risque inacceptable à un niveau tolérable, et comparez le risque résiduel au risque toléré.

Utilisez le cas que votre enseignant vous attribue. MediBec et CanaRetail sont des cas d'exercice dont les solutions sont publiques ; ils ne servent pas à ce travail.

**Consultant virtuel (parcours application de bureau) : [permis / non permis] pour ce travail.** S'il est permis, déclarez-le dans votre déclaration d'utilisation de l'IA et joignez les conversations sur lesquelles vous vous êtes appuyés (Outils → Consultant virtuel → *Historique* → *Exporter en Markdown*). S'il ne l'est pas, réglez *Consultant virtuel* et *Consultant virtuel — critique des paramètres* à **Désactivé** dans Paramètres → IA — locale et distante avant de commencer.

## 4.2 Livrables

1. Le fichier CyberRiskGuardian complété : le classeur (Analyse, S1–S10, M1–M10), l'exportation de l'espace de travail de l'application de bureau ou le fichier JSON de l'évaluation — selon les consignes de votre enseignant.
2. Un **mémorandum de direction d'une page** adressé à la direction.
3. Un **document de recommandation de deux pages** justifiant le portefeuille en fonction du rapport coût-efficacité, de la réduction du risque, des normes de l'industrie (ISO/IEC 27001/27002 ou NIST CSF 2.0), de la tolérance au risque et du budget.
4. Le **scénario de risque original S1** rédigé selon le modèle du cours (1 à 3 pages).

Les annexes sont permises et ne comptent pas dans les limites de pages.

## 4.3 Grille d'évaluation

| Critère | Pondération | Ce que démontre un travail solide (9–10) | Satisfaisant (6) | Plafonds |
|---|---|---|---|---|
| **Pertinence et originalité de S1** | 20 % | Un énoncé causal complet ancré dans des faits vérifiables du cas ; distinct de S2–S10 et de chaque exemple ; actifs principaux et de soutien, responsable, contrôles existants et preuves identifiés ; hypothèses qualifiées ; | Une chaîne causale reconnaissable, partiellement ancrée dans le cas ; certains éléments génériques | Une étiquette de menace au lieu d'un scénario de risque : max. 4. Une copie ou une variante |

| Critère | Pondération | Ce que démontre un travail solide (9–10) | Satisfaisant (6) | Plafonds |
|---|---|---|---|---|
| | | une vulnérabilité technique défendable pour le CVSS lorsque le CVSS s'applique | | rapprochée d'un scénario fourni : max. 3 |
| **Exhaustivité et précision de l'analyse des risques** | 20 % | Les dix scénarios complets ; chaque valeur dans sa plage ; $\delta m \geq \delta e$ ; $\theta > 0$ ; CVSS de 0 à 10 avec le vecteur conservé ; un seul horizon ; fichier recalculé ; justification de chaque chiffre ; chiffres concordant avec le mémorandum | Tous les scénarios présents avec leurs valeurs ; justification mince ; erreurs mineures de plage ou de cohérence | Chiffres inventés ou inexpliqués pour plusieurs scénarios : max. 5. Classeur non recalculé : max. 6 |
| **Pertinence des mesures d'atténuation** | 20 % | Contrôles reliés à des étapes de la chaîne causale et s'ajoutant aux contrôles existants ; chiffrés sur un seul horizon, les coûts partagés n'étant comptés qu'une fois ; réductions justifiées, aucune supérieure à 1,0 ; réalisables pour cette organisation ; aucun contrôle que le cas dit déjà en place | Contrôles raisonnables, partiellement justifiés ; certains éléments génériques ; coûts approximatifs | Réductions supérieures à 1 ou ensemble de mesures qui ne réduit qu'une seule dimension sans commentaire : max. 5 |
| **Clarté et argumentation du mémorandum** | 20 % | La décision d'abord ; les scénarios qui dépassent la tolérance ; le portefeuille recommandé ; le coût par rapport au budget ; le risque résiduel par rapport à la tolérance ; les principales incertitudes et les prochaines étapes ; une page ; cohérent avec le classeur | Clair mais descriptif ; la décision est présente mais ne vient pas en premier ; certains chiffres manquent | Chiffres qui contredisent le classeur : max. 5 |
| **Normes de présentation et qualité rédactionnelle** | 10 % | Format professionnel, terminologie cohérente, citations correctes, page titre complète, déclaration explicite sur l'IA, texte révisé | Généralement soigné ; quelques écarts | Aucune déclaration sur l'IA : max. 5 |
| **Synthèse et conclusion** | 10 % | Une vue d'ensemble du portefeuille : coût total par rapport au contexte budgétaire, scénarios sous la tolérance après | Une certaine priorisation ; vue du portefeuille limitée | — |

| Critère | Pondération | Ce que démontre un travail solide (9–10) | Satisfaisant (6) | Plafonds |
|---|---|---|---|---|
| **s stratégiques** | | traitement, priorités et séquencement, gains rapides, risques résiduels formellement acceptés et par qui | | |

## 4.4 Autovérification avant la remise

- ☐ S1 est un énoncé causal complet appuyé par des preuves tirées du cas et se distingue de S2–S10.
- ☐ Les dix scénarios sont complets ; les plages sont respectées ; θ n'est jamais nul ; les vecteurs sont conservés ; une seule version du CVSS est utilisée.
- ☐ Le fichier a été recalculé, et le mémorandum et la recommandation y correspondent à l'unité près.
- ☐ L'appétence pour le risque est énoncée et justifiée par rapport à la tolérance du cas ; le risque résiduel est comparé au risque toléré.
- ☐ Chaque mesure est reliée à un scénario et à une étape de sa chaîne, chiffrée sur un seul horizon et justifiée ; les mesures partagées ne sont comptées qu'une fois.
- ☐ Le mémorandum tient sur une page et commence par la décision ; la recommandation fait deux pages.
- ☐ Les trois mentions (**Estimation analytique — validation requise**, **Lacune d'information — validation organisationnelle requise**, **Décision de la direction requise**) apparaissent aux endroits appropriés ; la page titre, les citations et la déclaration sur l'IA sont complètes.

## 4.5 Conseils

- Distinguez la probabilité que la menace soit présente de la probabilité que l'exploitation réussisse.
- Donnez une brève justification et des preuves pour chaque chiffre, et indiquez les deux ou trois valeurs les plus incertaines.
- Le CVSS note une vulnérabilité technique définie, et non un scénario de risque entier.
- Le classeur (v2-6) valide les saisies et signale les problèmes dans sa colonne de contrôles (AC); lisez tout de même numériquement le risque estimé et le risque toléré plutôt que la couleur des cellules, remplacez la valeur provisoire d'appétence 0,5 et gardez chaque vecteur CVSS à côté de son score.
- Dans le mémorandum, indiquez combien de scénarios sont au-dessus de la tolérance avant et après traitement, ce que coûte le portefeuille et quel risque subsiste. Ne reprenez pas les tableaux.

# 5 A2 — Politique de sécurité de l'information : gestion des identités et des accès (en équipe)

**Équipe de 3 ou 4 · Remise [semaine] · [Pondération, p. ex. 10 %]**

## 5.1 Énoncé

Traduisez votre compréhension des risques de l'organisation en un document de gouvernance applicable : une **politique de gestion des identités et des accès (GIA)** officielle, mise en forme pour approbation par la direction, dans un langage qui fait le pont entre les opérations techniques et la gouvernance d'affaires. Ancrez-la dans votre cas et dans vos résultats de l'A1. Elle doit décrire les rôles et responsabilités, le traitement des exceptions, les conséquences de la non-conformité ainsi que la façon dont la conformité est surveillée et mesurée.

Format recommandé : une politique ciblée d'environ 3 à 5 pages, accompagnée d'une brève justification destinée à la direction et d'une carte hiérarchique montrant les normes, lignes directrices et procédures qui en découlent.

**Éléments probants tirés de l'application de bureau.** Si votre espace de travail pour le cas contient des registres de Gestion des identités et des accès (GIA/GAP) (laboratoire 13), vous pouvez les utiliser comme éléments probants : citez l'indicateur (par exemple CRG-18 Couverture de l'AMF des accès privilégiés) ou le constat avec son numéro E, et précisez si les décomptes sont confirmés ou inférés. Les registres contiennent des décomptes par population, jamais de noms. Ils appuient votre argumentation sans remplacer les faits du cas, et la grille d'évaluation est la même quel que soit le parcours.

**Consultant virtuel (parcours application de bureau) : [permis / non permis] pour ce travail.** S'il est permis, déclarez-le dans votre déclaration d'utilisation de l'IA et joignez les conversations sur lesquelles vous vous êtes appuyés (Outils → Consultant virtuel → *Historique* → *Exporter en Markdown*). S'il ne l'est pas, réglez *Consultant virtuel* et *Consultant virtuel — critique des paramètres* à **Désactivé** dans Paramètres → IA — locale et distante avant de commencer.

## 5.2 Grille d'évaluation

| Critère | Pondération | Ce que démontre un travail solide |
|---|---|---|
| Alignement sur les affaires et les risques | 15 % | Le risque lié à la GIA justifié par des faits du cas et des preuves de l'A1 ; « l'organisation a besoin de cette politique parce que **, *et elle sera réussie lorsque*** » |
| Alignement sur les cadres et les obligations | 10 % | NIST CSF 2.0 et ISO/IEC 27001/27002:2022 utilisés de façon sélective et exacte comme table de correspondance ; obligations légales ou contractuelles nommées à partir de sources faisant autorité ; aucune obligation légale inventée |
| Hiérarchie documentaire | 10 % | La politique distinguée des normes, lignes directrices et procédures ; une carte hiérarchique ; les valeurs techniques placées dans une norme ou une procédure nommée |
| Structure et exhaustivité | 15 % | Bloc de contrôle documentaire (titre, identifiant, version, statut, responsable, approbateur, dates, classification) ; objet ; portée ; définitions ; énoncés numérotés ; rôles ; exceptions ; surveillance de la conformité ; infractions ; documents connexes ; révision |
| Qualité des énoncés de politique | 20 % | Chaque énoncé nomme un acteur, utilise **doit** ou **ne doit pas**, énonce un résultat, un objet et une condition ; voix active ; vérifiable ; numéroté ; adressé à la personne qui peut réellement l'exécuter |

| Critère | Pondération | Ce que démontre un travail solide |
|---|---|---|
| Mise en œuvre et surveillance | 15 % | Preuves pour chaque énoncé important ; ICP avec cible, responsable, source de données, fréquence, voie de reddition de comptes et mesure corrective ; plan de communication ; prise de connaissance ; date d'entrée en vigueur et transition ; éléments déclencheurs de révision |
| Présentation professionnelle | 10 % | Concise, lisible, numérotation cohérente, références correctes, texte révisé ; page titre ; déclaration sur l'IA |
| Analyse originale | 5 % | Jugement propre à cette organisation ; solutions de rechange comparées |

**Vocabulaire normatif.** Utilisez un seul vocabulaire de façon cohérente : **doit** pour les obligations, **ne doit pas** pour les interdictions, **devrait** pour une recommandation qui admet des exceptions justifiées, **peut** pour une permission. Évitez « régulièrement », « rapidement », « approprié » et « dans la mesure du possible », à moins qu'une norme ne les définisse.

**Ce que couvre normalement une politique de GIA.** Cycle de vie des identités (arrivées, mutations, départs) ; authentification et AMF, avec des options plus robustes pour les accès privilégiés et à distance ; comptes de service et comptes non humains ; accès des tiers ; accès d'urgence (bris de glace) ; gestion des accès privilégiés et journalisation ; revues périodiques des accès ; séparation des tâches ; accès à distance et mobiles ; délais de désactivation au départ ; exceptions avec acceptation du risque, expiration et contrôles compensatoires.

**Volet application de bureau.** Gestion des PSI → *Bibliothèque des politiques* → *Contrôle d'accès et authentification* → *Créer à partir du gabarit* produit une ébauche dont les énoncés comportent un identifiant, une modalité ainsi que leurs contrôles ISO/IEC 27002:2022 et NIST CSF 2.0. Considérez-la comme un point de départ : la note porte sur votre adaptation au cas.

### 5.3 Autovérification

- ☐ La politique porte sur la GIA, est justifiée par des preuves tirées du cas et les résultats de l'A1, et précise ce à quoi ressemble la réussite.
- ☐ Un bloc de contrôle documentaire et une carte hiérarchique sont présents.
- ☐ Les énoncés sont numérotés, utilisent un seul vocabulaire normatif et précisent qui doit faire quoi, de manière vérifiable.
- ☐ Les rôles, les exceptions, la surveillance, les infractions et leur sanction, ainsi que la révision sont présents.
- ☐ Les ICP comportent des cibles, des responsables, des sources de données et des fréquences.
- ☐ Les références aux cadres sont à jour et exactes ; aucune obligation inventée.

## 6 A3 — Plan d'audit de cybersécurité fondé sur les risques (individuel)

**Individuel · Remise [semaine] · [Pondération, p. ex. 10 %]**

## 6.1 Énoncé

Rédigez un plan d'audit de cybersécurité officiel, fondé sur les risques, pour l'organisation du cas, en vous guidant sur le cadre d'audit interne vu en classe, sur COBIT 2019 et sur le guide GTAG de l'IIA portant sur l'élaboration du plan d'audit des TI. Cartographiez les actifs TI critiques, concentrez l'effort d'audit là où le cyberrisque est le plus élevé, définissez la portée de l'audit et concevez les tests des contrôles : objectifs, contrôles précis et procédures telles que les revues de configuration, l'analyse de données et les outils et techniques d'audit assistés par ordinateur (TAAO).

Structure recommandée : sommaire exécutif ; contexte de l'organisation et de l'audit ; univers d'audit ; méthode d'évaluation et classement des risques ; plan d'audit annuel ; feuille de route pluriannuelle ; plan de mission détaillé avec programme de travail ; méthode de test des contrôles ; rapport et suivi ; références et annexes.

**Consultant virtuel (parcours application de bureau) : [permis / non permis] pour ce travail.** S'il est permis, déclarez-le dans votre déclaration d'utilisation de l'IA et joignez les conversations sur lesquelles vous vous êtes appuyés (Outils → Consultant virtuel → *Historique* → *Exporter en Markdown*). S'il ne l'est pas, réglez *Consultant virtuel* et *Consultant virtuel — critique des paramètres* à **Désactivé** dans Paramètres → IA — locale et distante avant de commencer.

## 6.2 Grille d'évaluation

| Critère | Pondération | Ce que démontre un travail solide |
|---|---|---|
| Alignement sur les affaires et contexte | 10 % | Part des objectifs, des services critiques et des risques d'affaires ; mandat, destinataires, indépendance et autorité d'approbation clairs ; faits du cas utilisés, hypothèses qualifiées |
| Univers d'audit | 15 % | Environ 5 à 10 entités auditables par domaine (gouvernance, processus, information, personnes, technologie, tiers, résilience, changement), chacune avec un responsable, une limite de portée et un lien vers un service ou un risque — et non un inventaire matériel |
| Méthode d'évaluation et classement des risques | 20 % | Facteurs et pondérations totalisant 100 %, points d'ancrage de cotation, une formule, des preuves et une justification pour chaque cote, des niveaux de priorité, des dérogations documentées, une arithmétique recalculable ; les résultats de l'A1 utilisés comme intrant sans traiter le CVSS ou le ratio de tolérance de CRG comme la totalité de la priorité |
| Portefeuille annuel, feuille de route et ressources | 20 % | Missions retenues, reportées, combinées ou sur lesquelles on s'appuie, avec motifs ; omissions à risque élevé divulguées ; heures dont le total concorde, avec réserve et suivi ; compétences ; une feuille de route de trois ans ; autres sources d'assurance évaluées |
| Plan de mission détaillé et programme de travail | 25 % | Objectifs, portée, exclusions, critères ; une matrice risques-contrôles avec un test de conception et un test d'efficacité opérationnelle par contrôle clé ; méthodes de collecte de preuves ; échantillonnage (population, période, unité, méthode, taille) ; TAAO reliés à des risques précis, avec étapes de validation des données |

| Critère | Pondération | Ce que démontre un travail solide |
|---|---|---|
| Rapport, suivi et dynamisme | 5 % | Structure des constatations (critères, situation, cause, effet, recommandation, responsable, échéance) ; cotation des problèmes ; validation du suivi ; éléments déclencheurs de modification du plan |
| Présentation professionnelle | 5 % | Concise, référencée, cohérente, calculs traçables ; page titre ; déclaration sur l'IA |

**Volet application de bureau.** Gestion de l'audit → *Univers d'audit* → *Ajouter les actifs critiques et élevés absents de l'univers* ; *Plan d'audit* attribue un score aux entrées à partir du risque inhérent, du temps écoulé depuis le dernier audit et du risque résiduel de leurs scénarios, lu à partir du moteur. *Procédures · SP 800-53A* affiche les objectifs d'évaluation d'un contrôle. Les programmes de travail de CRGO sont fournis à titre d'illustration et ne constituent pas une méthodologie d'audit validée.

### 6.3 Autovérification

- ☐ Le plan part des objectifs d'affaires ; l'univers d'audit est structuré et sa taille est expliquée.
- ☐ La méthode de cotation, les pondérations (100 %), les points d'ancrage et l'arithmétique sont présentés, et le classement correspond à la sélection.
- ☐ Les missions retenues, reportées et omises sont expliquées ; le total des heures et des réserves concorde.
- ☐ Le plan de mission comporte une matrice risques-contrôles, des tests de conception et d'efficacité opérationnelle, un échantillonnage et des TAAO avec validation des données.
- ☐ Le rapport, le suivi et les éléments déclencheurs de modification du plan sont décrits.
- ☐ Si vous réutilisez les résultats de l'A1 de votre équipe, ils sont cités ; si vous auditez un contrôle que votre équipe a recommandé, la question de l'indépendance est abordée.

## 7 Formats plus courts

### 7.1 Portfolio de laboratoires (individuel, réussite/échec ou 10 %)

Les étudiants remettent les livrables des laboratoires 1 à 10 du Cahier de laboratoires de l'étudiant, en un seul PDF, accompagnés d'une réflexion d'une page : *Quelle estimation a le plus changé entre votre première ébauche et la version finale, et pourquoi ?* Évaluez l'exhaustivité (50 %), l'utilisation des trois mentions (25 %) et la réflexion (25 %).

### 7.2 Essai individuel sur un scénario de risque (individuel, 2 ou 3 pages)

Rédigez un scénario de risque original pour un cas attribué, quantifiez-le, établissez son vecteur CVSS et son score, calculez le risque estimé, le risque toléré et le risque résiduel pour un ensemble de mesures de traitement, et argumentez en une page si la direction devrait atténuer, transférer, éviter ou accepter le risque.

| Critère | Pondération |
|---|---|
| Chaîne causale et ancrage dans le cas | 30 % |

| Critère | Pondération |
|---|---|
| Paramètres, justification et CVSS | 30 % |
| Calcul et interprétation par rapport à la tolérance | 20 % |
| Recommandation et décision requise | 20 % |

### 7.3 Défi d'analyse rapide en classe (en équipe, 75 minutes)

Chaque équipe reçoit un profil d'organisation de deux pages qu'elle n'a jamais vu. À l'aide de `/crg-quick-scan` (volet Claude) ou de *Scénarios en lot* (volet application de bureau), l'équipe produit 20 scénarios candidats, en retient dix et présente un tableau de verdicts sur une seule diapositive. La classe vote ensuite pour le scénario de risque le mieux appuyé par le profil et celui qui l'est le moins. Évaluez la défense des choix, et non le résultat produit par l'IA.

### 7.4 Dissertation d'examen (individuelle, en personne, sans IA)

Une étude de cas est distribuée avant l'examen ; les étudiants peuvent préparer des scénarios de risque à l'avance, avec l'IA s'ils le déclarent, et les apporter à l'examen. Pendant l'examen, les étudiants répondent à une ou deux questions à développement (par exemple, classer trois scénarios et justifier le classement ; recommander un budget de cybersécurité au regard de l'appétence pour le risque énoncée ; expliquer au conseil d'administration pourquoi un scénario demeure au-dessus de la tolérance après traitement). Chaque critère est noté sur l'échelle de 0 à 10. L'Édition Éducateur contient un cas d'examen et un plan de l'examen.

## 8 Formulaire d'évaluation par les pairs pour les travaux d'équipe

Chaque membre de l'équipe remplit ce formulaire de façon confidentielle. L'enseignant peut l'utiliser pour ajuster les notes individuelles à l'intérieur d'une fourchette annoncée (par exemple ±10 %).

| Membre de l'équipe | Contribution (décrire) | Fiabilité (1–5) | Qualité (1–5) | Collaboration (1–5) |
|---|---|---|---|---|
| | | | | |
| | | | | |
| | | | | |

*Qui a vérifié les chiffres par rapport au classeur avant la remise ?* _____

*Qui a vérifié le contenu généré par l'IA par rapport au cas et aux sources primaires ?* _____

## 9 Déclaration d'utilisation de l'IA générative

À inclure près de la page titre ou en annexe :

> *J'ai / Nous avons utilisé [nom et version de l'outil — par exemple le Consultant virtuel de CyberRiskGuardian, avec le modèle indiqué dans son journal des décisions] pour [objectif : par exemple générer des idées de scénarios de risque, proposer des justifications de paramètres, vérifier la grammaire, résumer une source]. J'ai / Nous avons vérifié tous les résultats par rapport au cas et aux sources primaires, recalculé chaque*

*chiffre avec le moteur de CyberRiskGuardian, révisé le texte, et j'assume / nous assumons la responsabilité de l'ensemble du contenu. [Ou : Aucun outil d'IA générative n'a été utilisé dans ce travail.]*

**Règles.** L'IA générative est permise dans les travaux, avec cette déclaration, à moins que l'énoncé n'indique le contraire, et n'est pas permise pendant l'examen. Le Consultant virtuel de CyberRiskGuardian est un outil d'IA comme les autres : chaque énoncé précise s'il peut être utilisé. Vous êtes responsable de tout ce que vous remettez. Une source fabriquée ou introuvable constitue à la fois un problème de preuve et une question d'intégrité académique. Ne collez pas de documents confidentiels dans un service d'IA externe, sauf si vous y êtes autorisé.

*© 2026 Marc-André Léger. Sous licence CC BY-NC 4.0. Adapté du guide des travaux de l'auteur pour un cours de premier cycle en cybersécurité.*